安全攻击实例

信息系统安全是一门实战性很明显的课程。本着“从实践中来，到实践中去”的思想，下面讲述一个并非虚构的故事。

故事发生在一个发达国家，时间并不久远，故事的主人公名叫卡尔，深谙信息安全攻之术，他可不是一个喜欢通过恶作剧来炫耀自己的人，他实施信息安全攻击的意图非常明确，那就是获取经济利益。

在下面的叙述中，你会遇到一些英文表示，如果你对它们不熟悉，不要为此犯愁，就当它们只是一种记号好了。

1.1.1 场景一：诱惑与行动

一个偶然的机会，卡尔在媒体上看到了一篇有关一家公司发展情况介绍的文章，那家公司名叫“好运”，英文是“Good Luck Corporation”(注：记住英文名称有助于跟上后面的故事情节)。据文章介绍，好运公司发展非常迅速，仅一年时间，销售网点已遍布全国各地。

读了该介绍文章，卡尔顿时眼前一亮，似乎看到了商机。他想：好运公司扩张得这么迅速，想必在网络信息系统建设中也许还来不及慎重考虑安全防范措施问题，在信息安全方面应该是有机可乘的。于是，卡尔盯上了好运公司，计划把它作为自己的进攻对象。

在发动攻击之前，卡尔需要收集有关好运公司的更多资料，他立刻开始了针对好运公司的侦察行动。卡尔首先想到的就是光顾提供因特网域名登记公共服务信息的因特网信息中心(英文表示为 InterNIC)的网站，尝试从中收集好运公司的有用信息。这一试还颇有收获，卡尔从中得知好运公司网络系统的地址（即 IP 地址）范围是 α.b.c.0-255。

1.1.2 场景二：技术性的打探

卡尔决定借助好运公司的 IP 地址信息对该公司的网络信总系统进行扫描。为了防止可能存在的入侵检测系统(简称 IDS)的检测或入侵防御系统(简称 IPS)的阻拦，卡尔在因特网中找到一个可当作替罪羊利用的系统，在该系统中安装上 *FragRouter* 软件，以该系统作为中转进行扫描，避免自己的系统直接暴露在扫描信总通信的前方，如图 1.1 所示。

卡尔使用 *Cheops-ng* 软件工具探测好运公司的网络系统，看看该网络中有什么样的系统在运行。扫描发现，通过因特网可以访问到该网络中的三个系统。利用 *Cheops-ng* 软件提供的路径跟踪(即 traceroute)功能，卡尔获知，从系统布局上看，在这三个系统中，其中有一个系统位于其他两个系统的前端。

使用 Nmap 软件工具对这几个系统进行 SYN 扫描，卡尔发现其中有一个系统的 TCP 80 端口是打开的，这表明该系统是一个网站服务器(Wb 服务器)。另外两个系统没有打开的 TCP 端口，但用 Nmap 进行 UDP 扫描发现有一个系统的 UDP5 3 端口是打开的，这表明该系统是一个域名服务器(DNS 服务器)。另外一个系统没有任何打开的端口，卡尔用 *Firewalk* 软件

工具扫描发现该系统是一个包过滤防火墙，它的规则允许通过 TCP80 端口和 UDP53 端口对好运公司网络的非军事区（简称 DM 亿）进行访问。至此，卡尔基本摸清了好运公司网络的因特网 DM 亿和防火墙的一般结构，如图 1.2 所示。

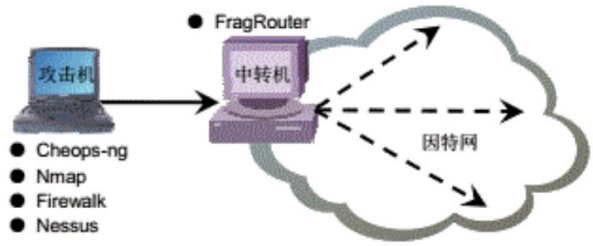

图 1.1　通过第三方系统进行扫描的方案

掌握了好运公司网络 DMZ 的基本情况，卡尔就运行 *Nessus 软*件工具对它进行漏洞扫描，看看其中有没有可以利用的简单漏洞存在，比如，检查一下其中是否存在有安全漏洞的服务或没有打安全漏洞补丁的服务可以利用。不幸的是，用 *Nessus* 进行的漏洞扫描并没有发现好运公司网络的 DMZ 中有什么可以利用的漏洞。

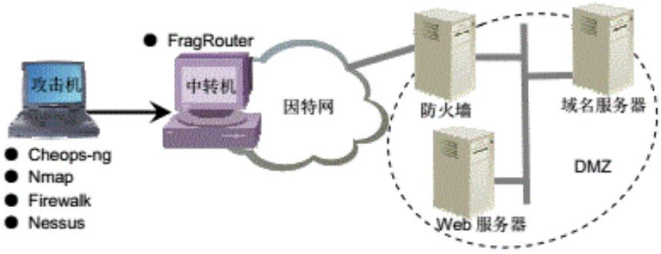

图 1.2　好运公司网络的因特网 DMZ 的基本结构

1.1.3 场景三：寻找突破口

首战未果并没有打消卡尔攻击好运公司的念头，他静下心来，浏览好运公司的网站信息，希望从中获得采取下一步行动的启发.好运公司网站的其中一个网页描述了该公司销售网点的分布情况。卡尔很快就发现，在离他家不远的地方，就有好运公司的一个销售点（不妨称为销售点 A)，他想：真是天赐良机。

于是，带上自己的笔记本电脑，卡尔驱车来到了销售点 A 的附近。就在自己的小汽车里，卡尔启动了配备着 Linux 系统的笔记本电脑，运行 ***Wellenreiter*** 软件工具，试图探测销售点 A 的无线网络接入点，如图 1.3 所示。

无线网络常简称为 Wi-Fi, Wi-Fi 接入点就是让电脑设备通过 Wi-Fi 连接到网络中去的入口。每个 Wi-Fi 接入点都有一个名称，专业术语叫 SSID。***Wellenreiter*** 工具功能比较强，就算 Wi-Fi 接入点的配置使通信包不包含 SSD 信息，或者不响应探测包，该工具也能把它探测出来。

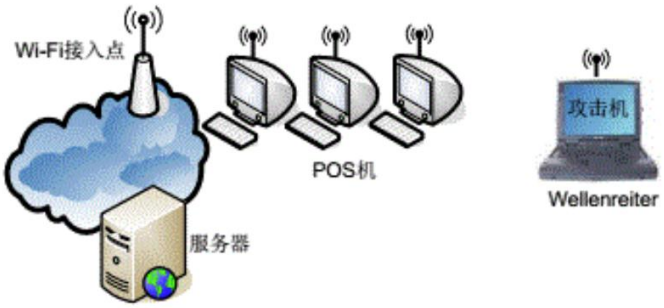

图 1.3　试图探测销售点的无线网络接入

通过查看 ***Wellenreiter*** 显示的合法通信信息，卡尔可以看到附近有若干 Wi-Fi 接入点，其中一个 SSD 为 *golucorp041* 的接入点引起了他的关注，他断定，那一定是销售点 A 的 Wi-Fi 接入点，因为，你还记得吧，该公司的英文名称是“Good Luck Corporation”，该 SSID 正隐含着该英文名称的缩写，而 041 估计是销售点的编号。

卡尔以 *golucorp041* 为 SSID 配置他的笔记本电脑上的 Wi-Fi 客户端，试图连接相应的 W-Fi 接入点。可是，连接并不顺利。该接入点好像具有包过滤功能，扔掉了他发送的所有通信包，不响应他的接入请求。卡尔仔细分析 *Wellenreiter* 的显示信息，忽然注意到了使用 golucorp0441 这个 SSD 的其他设备的网络物理地址（即 MAC 地址），这使他立刻想到：该接入点可能采取了 MAC 地址绑定措施，只允许具有指定 MAC 地址的设备进行连接。卡尔从 Wellenreiter 的显示信息中选取一个 MAC 地址，用 Linux 系统中的 *ifconfig* 命令。

把他的笔记本电脑的 MAC 地址伪造成该 MAC 地址，再次试图进行连接。果然连接成功，他的笔记本电脑通过 Wi-Fi 连接到了销售点 A 的内部网络中，并由该网络根据 DHCP 协议分配了动态 P 地址，如图 1.4 所示。

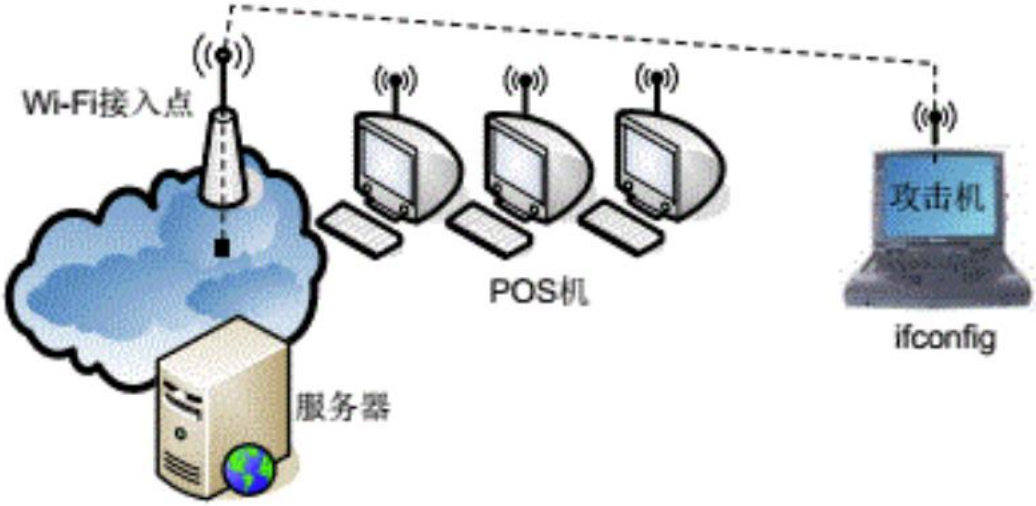

图 1.4　通过伪造 MAC 地址接入销售点 A 的网络

连接上了销售点 A 的内部网络系统后，卡尔使用 Nmap 工具中的 ping 扫描功能对该网络进行扫描，发现了连接到该网络中的无线销售终端机（即 POS 机）和销售点 A 的服务器的 IP 地址，使用 Linux 系统中的 *dig* 命令和该服务器的 IP 地址进行逆向 DNS 查询，他了解到了该服务器的域名是 *store041.internal.goodluck.com*。

根据 Nmap 的扫描结果，卡尔还发现，销售点 A 的服务器打开了 TCP 5900 端口，这表明该服务器可能运行着虚拟网络控制(VNC)服务。VNC 是一个常用的基于 GUI 的工具，允许管理员通过网络对系统进行远程控制，具有系统控制功能，通过它可以获得系统的重要信息。卡尔运行 *THC Hydra* 口令猜测工具对销售点 A 的 NC 服务的口令进行猜测，该工具对 root、admin 和 operator 等一系列常规的用户帐户进行逐个口令的猜测。令卡尔高兴的是，该工具发现 operator 帐户的口令竟是 *rotarepo*，它仅仅是帐户名字符串的倒写。

掌握了销售点 A 的 VNC 帐户和口令信总，卡尔便可以通过 VNC 堂而皇之地登录进入销售点 A 的服务器，并具有对系统的控制权，如图 1.5 所示。在这样的情况下，卡尔可以随意地对系统中的文件进行浏览，寻找他感兴趣的信息。

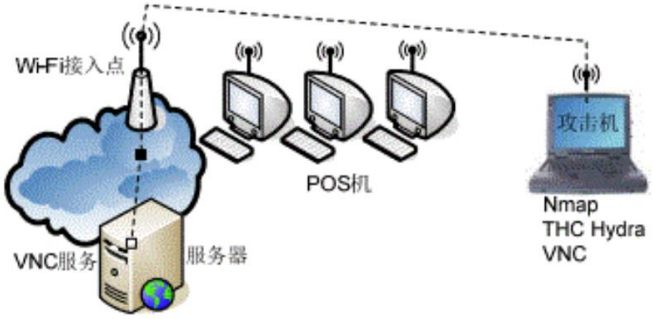

图 1.5　通过 VNC 进入销售点 A 的服务器

终于，在销售点 A 的服务器中的一个名称古怪的目录（即文件夹）下，卡尔发现了一个有价值的文件，该文件记录了 POS 机存放到销售点 A 的服务器上的交易历史信息，总共提供了该销售点 100 天以上的交易记录，其中包含有所有的信用卡信息（如卡号、持卡人姓名和有效期截止日等)。实际上，自该销售点服务器部署以来的所有交易信息都在该文件中。结果，仅从销售点 A 的服务器上，卡尔获得了超过 10 万张信用卡的信息。至此，卡尔对好运公司销售点 A 的攻击宣告成功。

获取信用卡信息正是卡尔对网络信息系统实施安全攻击所追求的目标，他总是以每张信用卡 1 美元的价格在黑市上出售信息卡信息，以此获利。当然，对于卡尔来说，每张 1 美元的价格是微不足道的，他的策略是薄利多销，以数量取胜。

1.1.4 场景四：设法扩大战果

因为卡尔是要靠数量发财的，所以，10 万张信用卡的信息还远远达不到他的期望，况且，多方面的资料显示，好运公司拥有遍布全国各地的 200 多个销售点，仅仅得手一个销售点岂能让他善罢甘休。而且，俗话说，万事开头难，现在，卡尔已经成功地攻入了好运公司销售点 A 的服务器系统，这意味着在攻击好运公司的网络信息系统的道路上，他已经开了个好局，也许，下一步的工作就容易得多了。

无论从哪个方面说，卡尔都不会就此终止对好运公司的兴趣。他回顾了对销售点 A 的攻击过程，自然会想到要攻击其他的销售点，但是，依次驱车前往各个销售点显然是件费力费时的差事。

分析成功攻入销售点 A 的服务器系统的基本要点，关键是该服务器系统提供了 VNC 服务并选择了容易猜测的口令。考虑到好运公司发展速度之惊人，卡尔推测各销售点的网络信息系统可能采用相同的模式进行部署，因而可以采取类似的攻击方法尝试攻击。

第二天，卡尔照样驱车来到销售点 A,希望借助在该销售点的 Wi-Fi 接入发动对其他销售点的攻击。他依然想采取 VNC 登录的方式去控制系统，但这一次，他不是采用与上一次相同的 IP 地址 *w.x.y.z* 去链接销售点 A 的 VNC 服务器，而是把 IP 地址调整为 *w.x.y+1.z*，居然也连接成功了，连接到另一个 VNC 服务器，如图 1.6 所示。夸张的是，这个 VNC 服务器上的帐户名和口令与销售点 A 的完全一样。可见，好运公司是采用完全照搬的方式部署各个销售点的网络信总系统的。这一次，卡尔真可谓不费吹灰之力便拿下了销售点 B,又得到了另一批信用卡的信息。

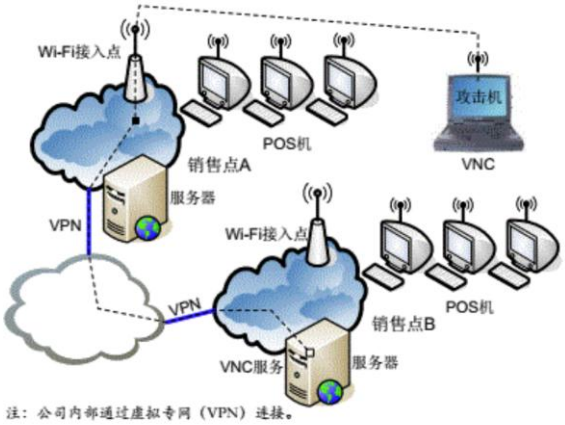

图 1.6　通过 VNC 进入销售点 B 的服务器

如此这般，照说，卡尔可以采取该方法逐个攻下各个销售点了。但要彻底把所有的销售点都过一遍，至少得重复类似的工作 200 多次，这样做并不省事，再说，万一哪个销售点修改了口令，这招也不见得灵。因此，卡尔设法尝试更加便捷的方法。

1.1.5 场景五：登上制胜之巅

卡尔再度分析对销售点 A 的服务器进行端口扫描得到的结果，他发现，该服务器运行着一个常用的备份程序，而且，众所周知，该备份程序含有缓冲区溢出漏洞。

凭借成功攻陷销售点 B 的 VNC 服务的直觉，卡尔推断销售点 B 的服务器可能也同样运行着相应的备份程序，因此，他在笔记本电脑的 Linux 系统中运行 Metasploit 攻击工具，尝试对销售点 B 的服务器上的备份程序发动缓冲区溢出攻击，不出所料，他果然成功了。

这时，在 Metasploit 工具的支持下，卡尔获得了销售点 B 的服务器的操作系统命令执行环境的完全控制权，借此机会，他在该服务器上安装了一个嗅探程序，如图 1.7 所示，目的是捕获经由销售点 B 的网络系统传输的各种信息。

销售点 B 的服务器中的嗅探程序为卡尔提供了该销售点上的 POS 机与服务器间传输的交易信息，诚然，这些对卡尔来说并没有太大的意义，因为通过该销售点上的 VNC 服务，他已经能够得到这些信息。不过，该嗅探程序还提供了非常有价值的信息，它显示，销售点 B 的服务器还向其他网络中的服务器发送交易请求，而且，这些交易请求是以明文传送的，

经过分析，卡尔发现，这些正是信用卡授权请求信息。

利用嗅探程序提供的接收授权请求信息的目的服务器的地址，卡尔运行 Nmap 工具对该目的服务器进行端口扫描。这一次，卡尔扫描的实际上是好运公司总部的中央网络系统中的服务器，它负责处理所有的信用卡交易并管理公司的业务。Nmap 扫描结果显示，该服务器开放了 TCP 443 端口，这表明该服务器应该是提供了一个 HTTPs 服务。

使用笔记本电脑上的浏览器，卡尔对好运公司总部服务器相关网站进行览，看到一个有关公司内部管理应用系统介绍的页面，该页面没有提供什么敏感信，只有一个入口，允许好运公司的内部员工登录进入一个 Web 应用程序，该程序能提供详详细的业务信息。没有合法的帐户和口令，是无法进入该应用系统的。卡尔尝试使用与 VNC 服务相同的帐户和口令，但并不奏效，使用 THC Hyra 工具进行口令猜测也没有取得成功。

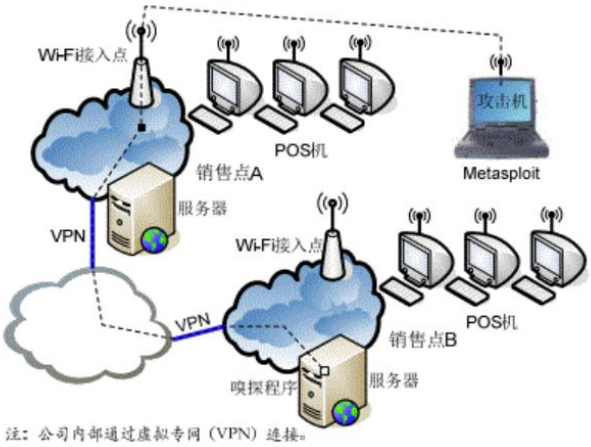

图 1.7　通过缓冲区溢出攻击植入嗅探程序

鉴于要对付 Web 应用系统，卡尔想到了称为 Web 应用掌控代理的工具，比如 Paros Proxy，这类工具运行在浏览器与 Web 应用之间，可以对 Web 应用实施有效攻击。于是，卡尔在笔记本电脑上启动了 Paros Proxy 工具，利用该工具的 Web 应用自动扫描功能，他尝试在好运公司的 Web 应用程序中查找跨站脚本和 SQL 注入漏洞。卡尔感到很庆幸，借助 Web 应用相关的网站会话历史状态信息（即 cookie 信息），该工具发现目标 Web 应用系统中存在 SQL 注入漏洞。

通过对 Paros Proxy 工具进行配置，把对 cookie 的操作模式设定为手工操作，卡尔利用 SQL 注入漏洞，攻入了好运公司总部的 Wb 应用系统，获得了对其后端数据库进行访问的机会，如图 1.8 所示。在该数据库中，卡尔发现了存放好运公司全部 200 多个销售点的所有顾客信息的一张表，其中含有 100 多万张信用卡的信息，这正是卡尔苦苦寻找的宝藏，他终于大功告成了。

至此，攻击的预定目的已经达到，卡尔随即撤离了现场，返回家中。接下来，通过他的地下销售途径，迅速出售获得的所有信用卡信息。最后，他销毁了所有与这次信用卡信息攻击行为有关的信息，开始度假，享受胜利果实。

1.1.6 场景六：尾声

卡尔的安全攻击措施是有效，但有关机构的安全响应措施也并非一无是处。两个星期之后，信用卡公司发现，一时间，出现了大量的信用卡欺骗行为。

通过对欺骗行为的相关系统审计信息进行分析，信用卡公司发现，涉案信用卡有一个共同点，那就是在过去的几个月里都曾经在好运公司的销售点进行过交易，由此意识到可能是好运公司出现了问题，并立即通知了好运公司。

好运公司由此展开了内部调查，并证实了安全事件的发生。按照有关法律规定，好运公司不得不告知所有信息被盗的信用卡持卡人，并履行相应的赔偿。毫无疑问，在由卡尔发动的这次信用卡信息盗窃安全事件中，好运公司遭受了惨痛的声誉和经济损失。

好了，故事就讲到这里，欲知卡尔命运如何，且听以后分解。可以透露的是，要想治罪他，就要证实他实施了攻击和窃取资料，这涉及到电子证据，计算机取证（又称数字取证）课程能让大家了解相关的调查取证技术。

1.2 安全攻击方法概括

在开篇案例中，卡尔采用多种方法对好运公司的网络信息系统进行了攻击，比如，通过 MAC 地址欺骗，取得了与公司内部网络的连接：通过口令破解，以远程控制方式登进了公司内部服务器：利用缓冲区溢出漏洞，闯进了操作系统工作环境，并拥有最高权限：借助 SQL 注入攻击，进入了内部 Web 应用系统。

攻击方法多种多样，随受攻击对象的当时情形而变化，但也并不是完全杂乱无章，有一定的规律可循。攻击是一步一步进行的，我们可以把攻击的过程划分成若干个环节。一般而言，网络信息安全攻击可以划分为侦察(Reconnaissance)、扫描(Scanning)、获取访问(Gaining Access)、维持访问(Maintaining Access)和掩盖踪迹(Covering Tracks)等阶段。

下面分别对各个阶段的基本思想、技术、工具和对策进行简要的介绍。

1.2.1 侦察

很多安全攻击都始于侦察阶段，在该阶段，攻击者想方设法收集尽量多的有关被攻击目标的信息，以便为实际的攻击做好准备。在开篇案例的场景一，卡尔所做的就是侦察方面的事情。

侦察阶段广泛采用的手段通常技术含量并不高。社会工程学(Social Engineering)便是常见的手段之一，它的特点就是通过普通谈话来诱导受害者透露敏感信息。电话交谈是社会工程学的常见形式，攻击者在电话中以花言巧语从用户口中套出电话号码、姓名、口令或其他敏感信息。攻击者也可能伪造来电号码以使受害者更容易上当。

淘垃圾(Dumpster Diving)也是一种值得关注的侦察手段，它指的是从一个单位遗弃的办公用品中搜寻敏感信息的过程，淘垃圾者可以从被扔掉的粘贴便条、光盘、旧硬盘等中获得

系统资料、用户名单、电话号码甚至口令信息。

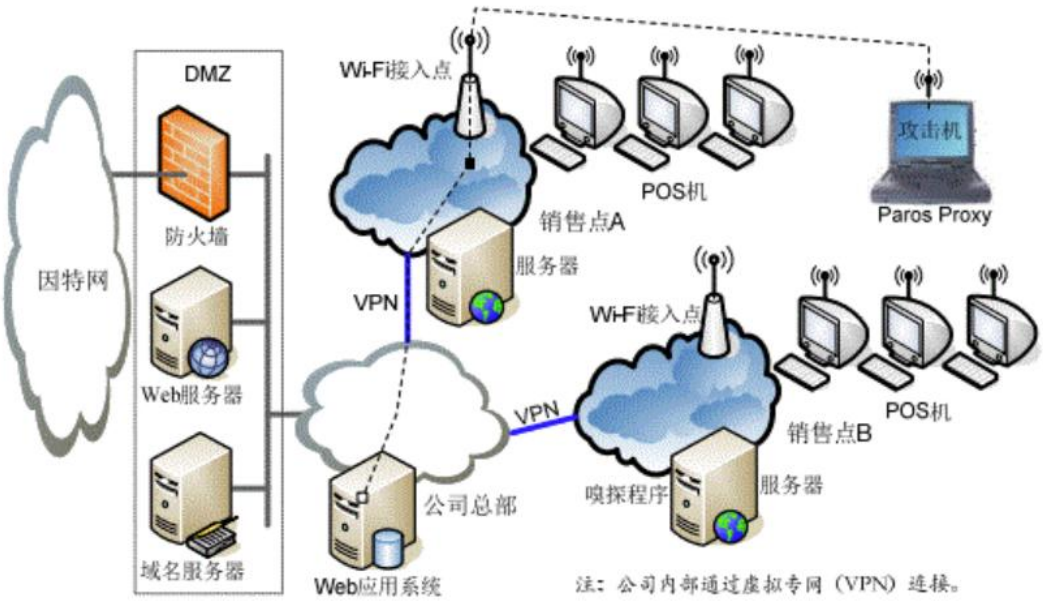

图 1.8　通过 SQL 注入攻击进入公司内部 Web 应用系统